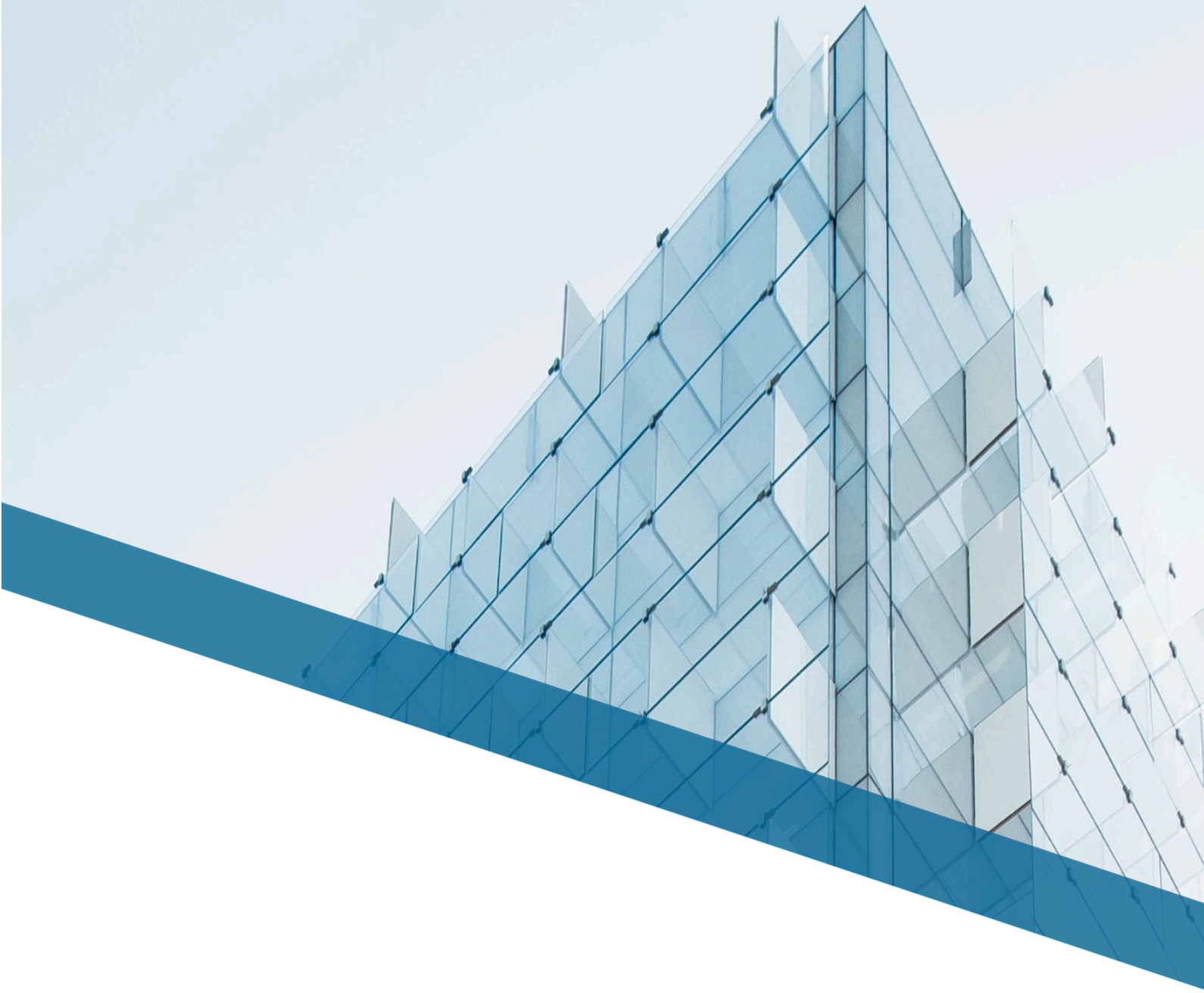


LAPORAN
Investigasi Forensik Digital Wazuh Lab

Bootcamp Cyber Security Batch 4

Disusun oleh: Satria Pamungkas

Februari 2026

DAFTAR ISI

DAFTAR ISI **2**
DAFTAR GAMBAR **3**
DAFTAR TABEL **4**
I. EXECUTIVE SUMMARY **5**
1.1 Latar Belakang 5
1.2 Artefak Barang Bukti 6
1.3 Temuan 6
1.4 Timeline 11
II. PEMBAHASAN **13**
2.1 Ruang Lingkup Analisis 13
2.2 Analisis Server 14
2.3 Penilaian Risiko (Risk Assessment) 18
2.5 Analisis Aktivitas Pasca-Eksploitasi 19
III. KESIMPULAN DAN SARAN **21**
3.1 Kesimpulan 21
3.2 Saran 21
LAMPIRAN **23**
Lampiran 1 Log AktivitasTargeted Brute Force 23
Lampiran 2 Log Aktivitas Massive Brute Force 23
REFERENSI **24**

DAFTAR GAMBAR

Gambar 1.3.1 Log Temuan Brute Force 7
Gambar 1.3.2 Temuan SSH Misconfiguration 8
Gambar 1.3.3 Temuan Database Misconfiguration 9
Gambar 1.3.4 Temuan File Integrity Changed 10
Gambar 1.3.5 Temuan Web Server Signature Disclosure 11

DAFTAR TABEL

Tabel 1.3.1 Hasil Temuan.....7
Tabel 1.4.1 Timeline Temuan..... 11
Tabel 2.1.1 Artefak digital yang menjadi ruang lingkup analisis.....13
Tabel 2.2.1 Timeline Serangan dari SIEM.....14
Tabel 2.2.2 MITRE ATT&CK Mapping..... 17
Tabel 2.3.1 Penilaian Resiko Matrix 5×5.....18
Tabel 2.5.1 Incident Response.....19

I. EXECUTIVE SUMMARY

1.1 Latar Belakang

Dibishop adalah platform e-commerce yang mengintegrasikan seluruh proses transaksi penjualan secara daring. Sebagai ujung tombak operasional perusahaan, keamanan infrastruktur Dibishop menjadi aset yang sangat vital. Namun, pemantauan keamanan secara real time melalui Wazuh SIEM mengidentifikasi adanya aktivitas anomali yang masif dan percobaan intrusi yang menargetkan server utama.

Insiden yang terdeteksi meliputi upaya serangan brute force yang terdistribusi secara global serta indikasi adanya akses tidak sah pada konfigurasi internal. Investigasi forensik dilakukan sebagai respons segera untuk mengidentifikasi sejauh mana aktor ancaman telah melakukan penetrasi, mencegah terjadinya kebocoran data sensitif, serta memastikan layanan tetap tersedia bagi konsumen.

Investigasi ini dilakukan untuk melakukan mitigasi sebelum kerentanan dieksploitasi lebih lanjut yang dapat mengakibatkan:

- Perubahan data transaksi atau skema database secara ilegal.
- Kebocoran data pribadi yang berpotensi melanggar regulasi UU PDP, yang dapat memicu denda berat dan kerusakan reputasi bisnis.
- Menentukan apakah insiden terjadi akibat serangan eksternal murni atau adanya celah dari kesalahan konfigurasi internal (misconfiguration).

Konteks sistem yang terdampak mencakup server production berbasis Ubuntu yang menjalankan layanan Apache Web Server dan MySQL Database. Investigasi dilakukan dengan mengumpulkan berbagai sumber bukti digital, antara lain:

- Wazuh SIEM & XDR, sebagai sumber utama alerting dan pemantauan integritas file (FIM).
- System & Auth Logs, digunakan untuk menganalisis timeline serangan brute force pada layanan SSH.

- Database General Query Log, digunakan untuk mengidentifikasi kebocoran informasi dan akses data tanpa otorisasi.
- Web Server Logs, digunakan untuk memetakan aktivitas vulnerability scanning yang menargetkan direktori sensitif website.

1.2 Artefak Barang Bukti

Dalam melakukan investigasi insiden pada infrastruktur Dibishop, telah dikumpulkan beberapa artefak digital yang berfungsi sebagai bukti untuk merekonstruksi aktivitas serangan. Berikut adalah daftar artefak yang digunakan:

- Wazuh SIEM Log, sumber utama yang mencatat alert keamanan, aktivitas file integrity monitoring, dan korelasi kejadian secara real time dari seluruh sistem.
- Server Authentication Logs (/var/log/auth.log), artefak ini digunakan untuk menganalisis upaya login pada layanan SSH, termasuk identifikasi alamat IP asal, timestamp, dan metode yang digunakan.
- Database General Query Log (/var/lib/mysql/srv974671.log), file log sistem database MySQL yang mencatat seluruh transaksi query secara plain text. Artefak ini menjadi bukti utama dalam identifikasi kebocoran informasi.
- Apache Web Server Logs, log akses yang mencatat setiap permintaan HTTP ke platform Dibishop, digunakan untuk mengidentifikasi pola vulnerability scanning.
- Threat Intelligence Feed, data eksternal yang digunakan untuk melakukan validasi reputasi alamat IP yang terdeteksi, guna memastikan apakah sumber serangan berasal dari botnet atau aktor ancaman yang sudah dikenal.

1.3 Temuan

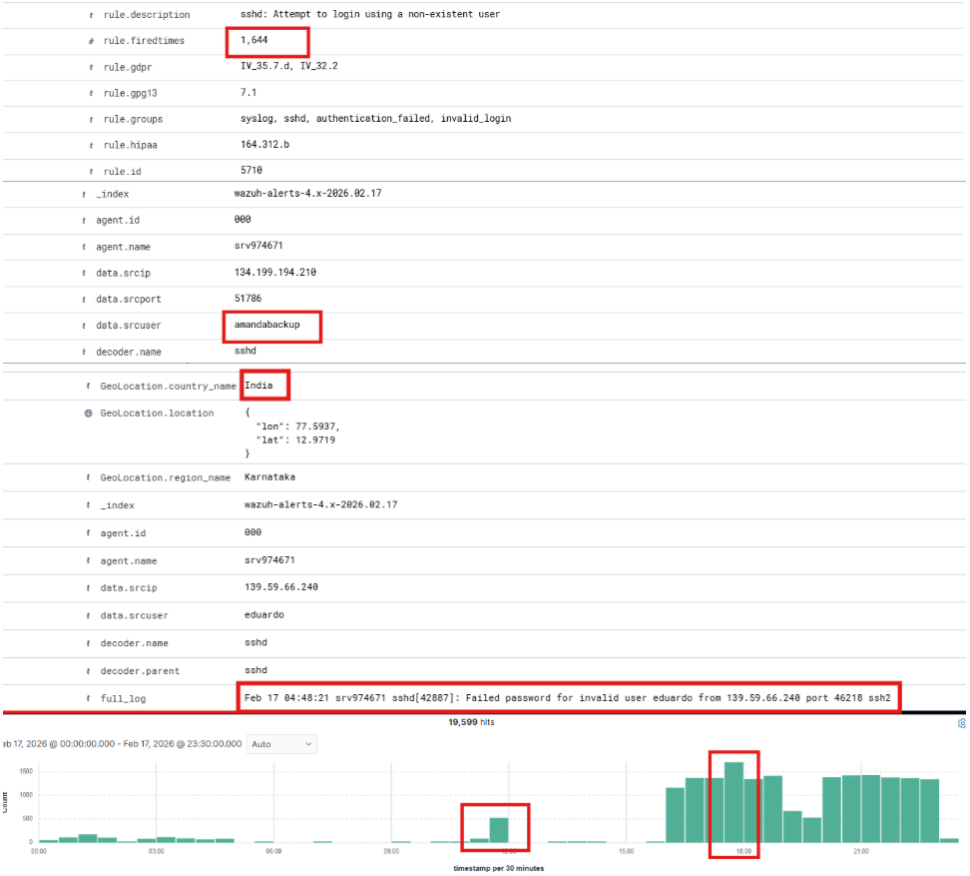
Hasil investigasi pada server Dibishop mengidentifikasi rangkaian serangan yang terstruktur, mulai dari percobaan akses tidak sah pada layanan SSH hingga eksploitasi celah keamanan pada aplikasi web.

Tabel 1.3.1 Hasil Temuan

SSH Brute Force Attack Analysis	Analisis korelasi rangkaian serangan SSH yang dimulai dari fase targeted testing hingga eskalasi menjadi massive distributed attack (serangan botnet) dari berbagai negara.
SSH Auth Misconfiguration	Akar masalah (Root Cause) berupa konfigurasi SSH yang mengizinkan login root langsung.
Database Information Disclosure	Kebocoran informasi sensitif dari database yang berhasil diidentifikasi.
Web Enumeration & Scanning	Upaya pemindaian celah web dan enumerasi direktori sistem.
Web Server Signature Disclosure	Munculnya detail service (Apache) yang digunakan.

Berikut merupakan temuan dari investigasi pada e-commerce Dibishop:

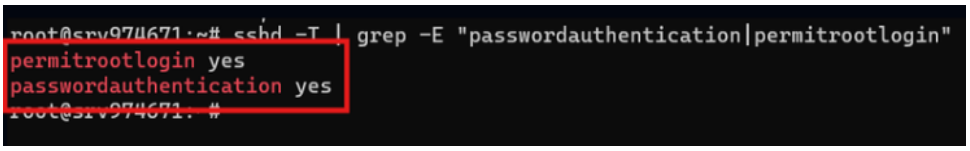
1. SSH Brute Force Attack Analysis



Gambar 1.3.1 Log Temuan Brute Force

- Terdeteksi percobaan login gagal yang menargetkan akun spesifik (user) dalam waktu singkat pada 17 Februari 2026. Penyerang melakukan pengujian awal untuk memvalidasi keberadaan akun “user” dan kekuatan kata sandi. Berdasarkan data Wazuh SIEM, aktivitas ini berasal dari satu IP tunggal dan berfungsi sebagai tahap reconnaissance sebelum meluncurkan serangan yang lebih besar.
- Setelah tahap pengujian, serangan meningkat menjadi lonjakan drastis pada log kegagalan autentikasi yang melibatkan hingga 1.644 percobaan login. Serangan bersifat distributed, di mana percobaan tidak lagi berasal dari satu sumber, melainkan dari ribuan alamat IP asing (seperti India dan Kanada) secara terus-menerus untuk menghindari deteksi berbasis rule IP tunggal.
- Aktivitas ini dapat menyebabkan resource exhaustion pada server akibat beban proses autentikasi yang banyak. Selain itu, pola serangan terdistribusi ini secara signifikan meningkatkan kemungkinan keberhasilan account takeover.

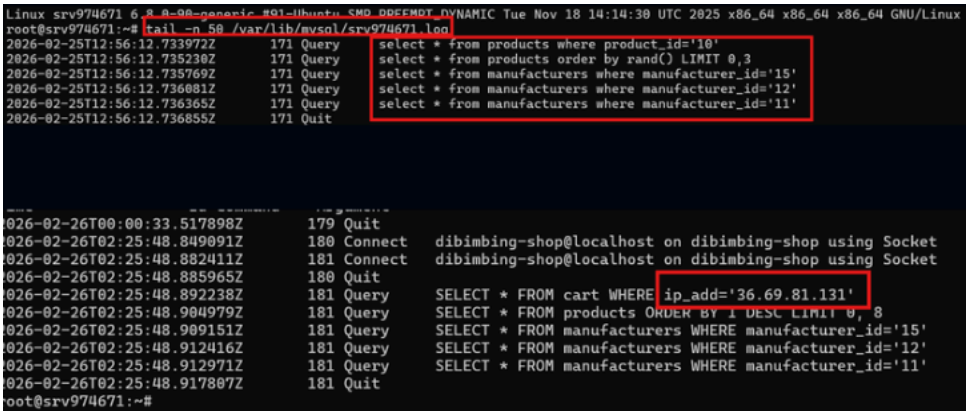
2. SSH Auth Misconfiguration (Root Cause)



Gambar 1.3.2 Temuan SSH Misconfiguration

- Ditemukan konfigurasi layanan SSH pada server mengizinkan login langsung menggunakan akun admin (PermitRootLogin Yes).
- Konfigurasi ini memungkinkan penyerang untuk langsung melakukan brute force terhadap akun "root". Jika serangan ini berhasil, penyerang otomatis mendapatkan kendali penuh seluruh sistem tanpa perlu melakukan privilege escalation.
- Sistem juga tidak membatasi jumlah kegagalan login dan tidak menggunakan public key authentication, sehingga penyerang bebas melakukan percobaan kata sandi secara berulang.
- Kesalahan konfigurasi SSH ini merupakan root cause serangan brute force sebelumnya.

3. Database Information Disclosure



Gambar 1.3.3 Temuan Database Misconfiguration

- Ditemukan bahwa sistem database memiliki log yang terlalu verbose.
- Log sistem secara terbuka menampilkan query SQL, nama tabel, dan IP pengguna di dalam error message yang dapat diakses tanpa akses root.
- Temuan ini dikategorikan sebagai information disclosure karena jika terjadi serangan, penyerang tidak perlu melakukan eksploitasi berat, penyerang cukup melihat log sistem untuk mendapatkan database dan informasi kredensial.
- Kesalahan konfigurasi aplikasi, di mana fitur debug tetap aktif pada lingkungan produksi.
- Kerentanan ini memudahkan penyerang untuk melakukan serangan seperti SQL Injection, karena informasi internal sistem sudah bocor melalui log tersebut.

4. Web Enumeration & Scanning

full_log	File '/etc/ld.so.cache' modified Mode: scheduled Changed attributes: inode,mtime Old modification time was: '1771308199', now it is '1771483309' Old inode was: '4753', now it is '6328'
id	1771524976.737163
input.type	log
location	syscheck
manager.name	srv974671
rule.description	Integrity checksum changed.
syscheck.mtime_after	Feb 19, 2026 @ 13:41:49.000
syscheck.mtime_before	Feb 17, 2026 @ 13:03:19.000
syscheck.path	/etc/ld.so.cache

Gambar 1.3.4 Temuan File Integrity Changed

- Terdeteksi aktivitas scanning dan enumerasi direktori secara masif yang menargetkan path /metasys/.
- Penyerang menggunakan IP 172.232.232.48 untuk melakukan directory fuzzing sebanyak 57 kali request dalam satu rangkaian kejadian.
- Aktivitas ini berkorelasi dengan adanya perubahan integritas pada file biner sistem /etc/ld.so.cache yang terdeteksi oleh fitur File Integrity Monitoring (FIM) Wazuh pada periode waktu yang sama.
- Modifikasi pada /etc/ld.so.cache mengindikasikan bahwa tahap enumerasi web tersebut berhasil masuk ke dalam sistem operasi, yang bertujuan untuk manipulasi library.
- Temuan ini menunjukkan bahwa penyerang telah melewati tahap reconnaissance dan melakukan manipulasi data pada komponen server Dibishop.

5. Web Server Signature Disclosure

```
analyst@srv974671:~$ curl -I http://localhost
HTTP/1.1 200 OK
Date: Fri, 06 Mar 2026 12:48:59 GMT
Server: Apache/2.4.58 (Ubuntu)
Last-Modified: Tue, 26 Aug 2025 02:29:19 GMT
ETag: "29af-63d3b70712158"
Accept-Ranges: bytes
Content-Length: 10671
Vary: Accept-Encoding
Content-Type: text/html
```

Gambar 1.3.5 Temuan Web Server Signature Disclosure

- Munculnya versi Apache mempermudah penyerang dalam melakukan vulnerability mapping untuk mencari celah keamanan yang relevan (CVE).
- Meskipun versi 2.4.58 telah di patched untuk menghindari kerentanan seperti CVE-2023-44487 (Rapid Reset), munculnya detail versi ini tetap berisiko karena penyerang dapat mencari celah keamanan lain.

1.4 Timeline

Tabel 1.4.1 Timeline Temuan

Tanggal	Kejadian
17 Feb 2026 – 04:48:16	Percobaan login SSH dari IP 144.126.192.12 (Baltimore, US) yang menargetkan akun 'user'.
17 Feb 2026 – 04:48:21	Meningkatnya serangan secara drastis percobaan login yang berasal dari berbagai IP negara lain.
19 Feb 2026 – 07:33:30	Penyerang melakukan 57 kali directory fuzzing pada path /metasys/.
19 Feb 2026 – 13:41:49	Terjadi modifikasi pada file sistem /etc/ld.so.cache yang berkorelasi dengan aktivitas web sebelumnya.

20 Feb 2026 – 01:16:16	Alert Wazuh (Rule 550) secara otomatis mengkonfirmasi adanya perubahan integritas pada sistem.
21 Feb 2026 - 06 Mar 2026	Audit Keamanan, mengungkap miskonfigurasi pada SSH (PermitRootLogin), paparan versi layanan pada HTTP Header (Apache/2.4.58), serta verbose logging pada database.

II. PEMBAHASAN

2.1 Ruang Lingkup Analisis

Proses investigasi ini dilakukan berdasarkan pedoman Rules of Engagement (RoE) yang telah ditetapkan untuk memastikan analisis berjalan secara terstruktur dan sesuai batasan. Fokus utama investigasi adalah melakukan deteksi dan analisis mendalam terhadap anomali pada server Dibishop guna menemukan indikasi insiden keamanan.

Rules of Engagement (RoE):

- Baca dan pahami dokumen terkait rules of engagement yang mencakup batasan dan cakupan uji coba.
- Website digunakan untuk observasi.
- Server dan log berisikan dari beberapa jenis misconfiguration, attack/attack attempt, maupun indikasi insiden, student harus menemukan minimal 4.
- Buat rencana analisis yang mencakup prosedur analisis dan pengumpulan evidence.

Tabel 2.1.1 Artefak digital yang menjadi ruang lingkup analisis

No	Nama Perangkat/ Dokumen	Detail Artefak	Keterangan
1	Server Dibishop	SSH Auth Logs	1.644 firedtimes percobaan login ilegal.
		System Integrity (FIM)	perubahan integritas pada file /etc/ld.so.cache.
2	Web services	Web Access Log	Percobaan 57 kali directory fuzzing pada path /metasys/.
3	Configuration	SSH, HTTP Header, Database Config	Misconfiguration pada konfigurasi sistem login SSH, HTTP header dan verbose logging pada

			database.
4	Dashboard SIEM	Alert & Visualization	Visualisasi untuk mengetahui lonjakan serangan.

2.2 Analisis Server

Tahap ini berfokus pada pemeriksaan log dan aktivitas server untuk menjawab bagaimana pola serangan terjadi dan apa dampak yang ditimbulkan pada sistem.

A. Timeline serangan dari SIEM

Tabel 2.2.1 Timeline Serangan dari SIEM

Tanggal	Kejadian
17 Feb 2026 – 04:48:16	Percobaan login SSH dari IP 144.126.192.12 (Baltimore, US) yang menargetkan akun 'user'.
17 Feb 2026 – 04:48:21	Meningkatnya serangan secara drastis percobaan login yang berasal dari berbagai IP negara lain.
19 Feb 2026 – 07:33:30	Penyerang melakukan 57 kali directory fuzzing pada path /metasys/.
19 Feb 2026 – 13:41:49	Terjadi modifikasi pada file sistem /etc/ld.so.cache yang berkorelasi dengan aktivitas web sebelumnya.
20 Feb 2026 – 01:16:16	Alert Wazuh (Rule 550) secara otomatis mengkonfirmasi adanya perubahan integritas pada sistem.
21 Feb 2026 - 06 Mar 2026	Audit Keamanan, mengungkap miskonfigurasi pada SSH (PermitRootLogin), paparan versi layanan pada HTTP Header (Apache/2.4.58), serta verbose logging pada database.

B. Korelasi Antar Event

Berdasarkan analisis log pada SIEM, ditemukan event chain sebagai berikut:

- Tahap 1: Initial recon, penyerang melakukan tes awal pada akun 'user' dari IP Baltimore (144.126.192.12) untuk memvalidasi keberadaan akun.
- Tahap 2: Massive brute force hanya berselang 5 detik dari tahap 1, serangan berubah menjadi agresif dengan melibatkan ribuan percobaan login dari berbagai negara (India, Canada, USA).
- Tahap 3: Penyerang mencoba jalur akses lain melalui aplikasi web dengan melakukan 57 kali directory fuzzing pada path /metasys/.
- Stage 4: Tahap sebelumnya pada web tersebut berkorelasi langsung dengan modifikasi file sistem kritis /etc/ld.so.cache yang memicu alert integritas dari Wazuh.

A. Analisis Log Server Penting
   - Auth Logs, mencatat ribuan percobaan login gagal (Failed password for invalid user) yang membuktikan adanya upaya serangan pada layanan SSH.
   - Web Server Access Log, menunjukkan pola serangan otomatis melalui 57 request beruntun pada direktori yang tidak seharusnya (/metasys/).
   - Integrity Logs, alert rule 550 mengkonfirmasi adanya perubahan checksum pada file biner sistem tepat setelah aktivitas web yang mencurigakan.

B. Analisis Aktivitas Serangan
   - Apa yang dilakukan attacker setelah masuk?
     Berdasarkan korelasi log web dan sistem pada 19 Februari 2026, penyerang melakukan upaya eksploitasi lebih lanjut setelah fase brute force. Penyerang melakukan 57 kali directory fuzzing pada jalur /metasys/ untuk mengetahui struktur aplikasi web dan mencari file sensitif. Penyerang berhasil memodifikasi file sistem /etc/ld.so.cache. Aktivitas ini menunjukkan upaya penyerang untuk memasukkan library berbahaya atau melakukan persistence.

   - Bagaimana privilege berubah?
     Meskipun belum ditemukan log mengenai "success login" yang

diikuti perintah sudo, indikasi perubahan privilege terlihat dari target dan hasil modifikasi. Penyerang secara konsisten menargetkan akun dengan hak akses admin seperti root, admin, dan amandabackup. Keberhasilan memodifikasi file di direktori /etc/ secara teknis menunjukkan bahwa penyerang telah memperoleh atau memanfaatkan celah yang memiliki hak akses setingkat root.

- Apa pola aktivitasnya?
  Pola aktivitas penyerang menunjukkan pola yang terorganisir dengan tahapan seperti, dimulai dengan percobaan dari IP tunggal pada fase awal untuk memeriksa respon keamanan. Penyerang kemudian beralih menggunakan ribuan IP lintas negara (botnet) dalam hitungan detik untuk melakukan serangan secara masif untuk mempercepat proses penemuan kredensial. Penyerang tidak terpaku pada satu jalur, ketika SSH sulit ditembus, penyerang beralih ke eksploitasi aplikasi web (/metasys/) sebagai jalur masuk alternatif.

C. Correlation SIEM

- SIEM Alert Analysis
  - Rule 5712 (Level 10) - SSH Brute Force, dipicu karena adanya percobaan login gagal yang melampaui ambang batas dalam waktu singkat.
  - Rule 550 (Level 7) - Integrity Check, dipicu karena modul syscheck mendeteksi adanya perubahan pada file /etc/ld.so.cache. Meskipun berada di Level 7, temuan ini sangat kritikal karena melibatkan file sistem yang dimiliki oleh root.
- SIEM Correlated Event Chain
  - Server Log > Web Log > Integrity Log (FIM).
  - Serangan dimulai dengan upaya mendapatkan kredensial via SSH. Kegagalan pada fase ini diikuti oleh aktivitas directory fuzzing pada aplikasi web tanggal 19 Februari. Puncaknya,

korelasi waktu menunjukkan bahwa segera setelah aktivitas web tersebut, terjadi modifikasi tidak sah pada file /etc/ld.so.cache.

- MITRE ATT&CK Mapping

Tabel 2.2.2 MITRE ATT&CK Mapping

Taktik	Taktik	Teknik	Bukti
SSH Brute Force Analysis	Credential Access (TA0006)	Brute Force (T1110)	Percobaan login dari IP tunggal pada akun 'user'
	Credential Access (TA0006)	Password Guessing (T1110.001)	Percobaan login yang gagal dengan frekuensi tinggi dari berbagai negara
	Lateral Movement (TA0008)	Remote Service: SSH (T1021.004)	Upaya berpindah antar akun sistem melalui SSH.
SSH Auth Misconfig	Initial Access (TA0001)	Exploit Public Facing App (T1190)	Pemanfaatan miskonfigurasi SSH (PermitRootLogin) sebagai pintu masuk utama.
	Credential Access (TA0006)	Password Guessing (T1110.001)	Percobaan serangan dengan brute force
Database Information Disclosure	Discovery (TA0007)	System Information Discovery (T1082)	Munculnya data sensitif pada log database
Web Scanning & Enumeration	Reconnaissance (TA0043)	Active Scanning (T1595)	57 kali percobaan fuzzing pada direktori /metasys/.
	Impact (TA0040)	Stored Data Manipulation (T1565.001)	Modifikasi file /etc/ld.so.cache

Web Server Signature Disclosure	Reconnaissance (TA0043)	Gather Victim Host Information Software (T1592.002)	Versi header membocorkan versi spesifik Apache/2.4.58 (Ubuntu)

2.3 Penilaian Risiko (Risk Assessment)

1. Analisis Dampak CIA dan Risiko Lanjutan:
   - Confidentiality

     Dampak tinggi karena adanya verbose logging database yang membocorkan informasi teknis dan upaya brute force pada akun administratif.
   - Integrity

     Dampak Kritis akibat modifikasi tidak sah pada /etc/ld.so.cache yang merusak kepercayaan pada sistem.
   - Availability

     Dampak Sedang karena beban kerja resource server meningkat akibat serangan distributed brute force yang masif.
   - Resiko Jangka Pendek & Panjang

     Potensi lateral movement menggunakan kredensial hasil brute force dan risiko persistence melalui manipulasi file sistem.
2. Tabel Risk Assessment

Tabel 2.3.1 Penilaian Resiko Matrix 5×5

Temuan	Dampak	Impact x Likelihood	Skor	Tingkat Kerentanan
SSH Auth Misconfiguration	Full Root Access	5×5	25	Very High
SSH Brute Force Attack Analysis	Ancaman pada integritas akun user dan mengancam sisi availability server	4×5	20	Very High

Web Scanning & Enumeration	Penyerang berhasil melakukan modifikasi file pada /etc/	4×5	20	Very High
Database Information Disclosure	Kebocoran data sensitif & Pelanggaran compliance	3×3	9	Moderate
Web Server Signature Disclosure	Memudahkan penyerang berfokus pada payload untuk versi yang bocor (CVE)	2×4	8	Moderate

2.5 Analisis Aktivitas Pasca-Eksploitasi

Analisis ini berfokus pada tindakan yang dilakukan pelaku setelah berhasil menembus celah keamanan, khususnya terkait upaya mempertahankan akses dan manipulasi sistem.

A. Incident Response & MITRE Mapping

Tabel 2.5.1 Incident Response

Phase	Technique	Evidence
Initial Access	T1078 – Valid Accounts	Eksploitasi terhadap celah PermitRootLogin pada 17 Feb yang memicu rangkaian serangan SSH.
Exploitation	T1110.001 - Password Guessing	1.644 percobaan login SSH gagal dari berbagai negara
Reconnaissance	T1595.002 – Vulnerability Scanning	57 kali percobaan fuzzing direktori /metasys/
	T1592.002 – Software	Versi Apache/2.4.58 yang terekspose memudahkan penyerang mencari CVE.
Impact	T1565.001 - Stored	Modifikasi tidak sah pada file

	Data Manipulation	sistem /etc/ld.so.cache
Discovery	T1082 - System Information Discovery	Verbose logging database yang mengekspos informasi sensitif

B. Rekomendasi Hardening

- Ubah konfigurasi PermitRootLogin menjadi no untuk mencegah akses root langsung.
- Implementasikan key based authentication dan menonaktifkan password authentication.
- Memasang Fail2Ban agar otomatis memblokir IP yang melakukan percobaan login gagal berulang kali.
- Mengubah pemindaian Wazuh dari scheduled menjadi real time untuk folder kritis /etc/ dan /bin/ agar setiap perubahan terdeteksi seketika.
- Memastikan aplikasi web tidak berjalan dengan hak akses root dan membatasi izin tulis pada direktori sistem.
- Memperkuat konfigurasi WAF untuk mendeteksi dan memblokir aktivitas directory fuzzing secara otomatis
- Mematikan mode debug/verbose pada semua layanan database di lingkungan produksi.
- Konfigurasi ServerTokens Prod dan ServerSignature off pada Apache. agar hanya merespon "Apache" tanpa versi dan menghapus baris informasi server yang biasanya muncul di bagian bawah halaman error.

III. KESIMPULAN DAN SARAN

3.1 Kesimpulan

Berdasarkan hasil investigasi dan analisis mendalam terhadap aktivitas log pada server Dibishop, dapat disimpulkan bahwa:

- Server Dibishop aktif menjadi target serangan eksternal, mulai dari Massive Distributed Brute Force (1.644 percobaan) hingga Web Directory Fuzzing. Meskipun Wazuh berhasil memberikan alert, deteksi pada beberapa file kritis masih bersifat terjadwal (scheduled), bukan real time.
- Penyerang berhasil melakukan enumeration dan melakukan modifikasi tidak sah pada file sistem /etc/ld.so.cache. Hal ini menunjukkan adanya celah pada privilege yang memungkinkan akun root diakses melalui miskonfigurasi SSH PermitRootLogin.
- Ditemukan kerentanan pada konfigurasi database yang masih dalam mode verbose, serta versi layanan pada Apache, sehingga membocorkan informasi internal yang dapat digunakan penyerang untuk discovery kerentanan (CVE).
- Terdapat indikasi pelanggaran regulasi perlindungan data (UU PDP), akibat adanya konfigurasi development yang terbawa ke lingkungan produksi, yang secara signifikan meningkatkan attack surface.

3.2 Saran

Berdasarkan temuan investigasi, berikut adalah langkah-langkah mitigasi yang direkomendasikan untuk memperkuat postur keamanan server Dibishop:

- Mengubah konfigurasi /etc/ssh/sshd_config dengan mengatur PermitRootLogin no dan PasswordAuthentication no untuk menutup jalur akses root langsung.
- Melakukan backup file /etc/ld.so.cache dari sumber yang terverifikasi untuk memastikan tidak ada malicious code yang tertinggal.
- Mengubah level logging pada layanan database dari mode verbose ke mode error only untuk mencegah kebocoran informasi sensitif.

- Melakukan penguatan pada web server dengan mengkonfigurasi ServerTokens Prod dan ServerSignature off pada Apache untuk menyembunyikan detail versi layanan dari publik.
- Mewajibkan penggunaan SSH Key untuk pengguna yang memiliki akses root.
- Mengkonfigurasi ulang modul File Integrity Monitoring (FIM) dari mode scheduled ke mode real-time untuk direktori sensitif seperti /etc/, /bin/, dan /sbin/.

LAMPIRAN

Data log asli atau yang telah difilter yang menunjukkan percobaan login secara masif (brute force) dan informasi terkait (seperti IP, waktu, username yang digunakan).

Lampiran 1 Log AktivitasTargeted Brute Force


```
{
 "_index": "wazuh-alerts-4.x-2026.02.17",
 "rule": {
  "id": "5712",
  "level": 10,
  "description": "sshd: brute force trying to get access to the system"
 },
 "data": {
  "srcip": "144.126.192.12",
  "dstuser": "user"
 },
 "full_log": "Feb 17 04:48:16 srv974671 sshd[41887]: Failed password for user
from 144.126.192.12 port 46216 ssh2"
}
```


Lampiran 2 Log Aktivitas Massive Brute Force


```
{
 "_index": "wazuh-alerts-4.x-2026.02.17",
 "rule": {
  "id": "5710",
  "level": 5,
  "description": "sshd: Attempt to login using a non-existent user",
```

```
  "firedtimes": 1644
 },
 "data": {
  "srcip": "134.199.194.210",
  "srcport": "51706",
  "srcuser": "amandabackup"
 },
 "location": "/var/log/auth.log",
 "full_log": "Feb 17 10:59:58 srv974671 sshd[52027]: Invalid user
amandabackup from 134.199.194.210"
}
```


REFERENSI

Berikut merupakan referensi yang digunakan:

- Credential Access, Tactic TA0006 - Enterprise | MITRE ATT&CK®
- Brute Force, Technique T1110 - Enterprise | MITRE ATT&CK®
- Brute Force: Password Guessing, Sub-technique T1110.001 - Enterprise | MITRE ATT&CK®
- Initial Access, Tactic TA0001 - Enterprise | MITRE ATT&CK®
- Discovery, Tactic TA0007 - Enterprise | MITRE ATT&CK®
- System Information Discovery, Technique T1082 - Enterprise | MITRE ATT&CK®
- Reconnaissance, Tactic TA0043 - Enterprise | MITRE ATT&CK®
- Active Scanning, Technique T1595 - Enterprise | MITRE ATT&CK®
- Impact, Tactic TA0040 - Enterprise | MITRE ATT&CK®
- Data Manipulation: Stored Data Manipulation, Sub-technique T1565.001 - Enterprise | MITRE ATT&CK®
- Valid Accounts, Technique T1078 - Enterprise | MITRE ATT&CK®
- Active Scanning: Vulnerability Scanning, Sub-technique T1595.002 - Enterprise | MITRE ATT&CK®
- Data Manipulation: Stored Data Manipulation, Sub-technique T1565.001 - Enterprise | MITRE ATT&CK®

- System Information Discovery, Technique T1082 - Enterprise | MITRE ATT&CK®
- Gather Victim Host Information, Technique T1592 - Enterprise | MITRE ATT&CK®